



CS 03500 - Foundations of Cybersecurity

Project Part 2:
Gap Analysis Plan

Name: Devon Jacob

Instructor: Michael Davie

Date: 10/01/2024

Gap Analysis

A gap analysis of the IT environment was conducted to identify threats and vulnerabilities and to develop strategies for mitigating future risks at Fullsoft. This comprehensive assessment aims to enhance the organization's overall security posture and ensure the protection of critical assets.

To thoroughly analyze Fullsoft's IT environment, crucial information was gathered through interviews with key personnel in the IT department. Additionally, technical assessments were conducted to evaluate access controls, encryption practices, and incident reporting procedures.

Objective 1: Data Management/ Data Classification Standards

Goal: To implement and clearly define data classification levels as Restricted, Confidential, Internal and Public.

Information Gathering: A comprehensive evaluation was conducted at Fullsoft to assess the current data classification policies and their effectiveness in categorizing sensitive information.

Current Status:

- The evaluation revealed that Fullsoft lacks a formal data classification policy, leading to inconsistent data handling and potential security risks.
- Additionally, staff were not fully aware of the importance of data classification or the specific categories within the organization.

Required Changes:

- Develop a comprehensive data classification policy that clearly outlines the definitions and handling procedures for Restricted, Confidential, Internal and Public Data.
- Organize training sessions focused on data classification and handling procedures to ensure all employees understand their roles in protecting sensitive information.

Objective 2: Access Control

Goal: To develop a strict access control policy limiting access to sensitive information.

Information Gathering: An in-depth assessment of the company's access control measures was performed to evaluate user access privileges to sensitive information.

Current Status:

- At Fullsoft, some employees have excessive permissions based on their roles in the organization.
- The assessment also revealed that many staff members lacked Multi-Factor Authentication (MFA), posing a risk of unauthorized access to sensitive information.

Required Changes:

- Implementing role-based access control (RBAC) will ensure that employees are restricted to accessing only the data relevant to their specific roles.
- Develop a strict policy requiring employees with access to sensitive information to have multi-factor authentication (MFA).

Objective 3: Risk Assessment

Goal: To create a systematic risk assessment process that identifies risks to sensitive information.

Information Gathering: A vulnerability-based methodology was employed to define the scope of Fullsoft's risk assessment. This approach analyzed known weaknesses and deficiencies within the organizational system.

Current Status:

- The finding determined that Fullsoft currently does not conduct risk assessments on a regular or systematic basis, leading to an unclear understanding of existing vulnerabilities.

Required Changes:

- Adopt the OCTAVE Allegro framework for conducting risk assessments to guarantee a consistent and systematic methodology.
- Create a timetable for regular risk assessments to consistently identify and mitigate vulnerabilities.

Objective 4: Encryption Practices

Goal: Adopt secure encryption methods to safeguard sensitive data both at rest and during transmission.

Information Gathering: A detailed assessment of the encryption practices for sensitive data was conducted to gain a better understanding of Fullsoft's encryption strategies.

Current Status:

- Fullsoft currently utilizes inconsistent encryption methods across various systems and data types, resulting in potential security vulnerabilities.
- Some staff members do not fully comprehend the importance and effectiveness of encryption in safeguarding sensitive information.

Required Changes:

- Develop and implement a formal policy that specifies encryption standards and practices for all sensitive data.
- Conduct training sessions to raise employee awareness of the importance of encryption and proper implementation techniques.

Objective 5: Incident Reporting

Goal: Create a systematic and effective incident reporting system to guarantee the prompt identification, response, and documentation of security incidents.

Information Gathering: An analysis of the existing procedures for reporting security incidents was conducted to evaluate its effectiveness.

Current Status:

- Fullsoft currently does not have a formal incident reporting process, leading to delayed responses to security incidents and the risk of information loss.

Required Changes:

- Develop and enforce a detailed policy that specifies the procedures for reporting security incidents, including timelines and designated responsibilities.
- Set up a centralized platform to facilitate easy incident reporting by employees, ensuring that reports are effectively tracked and managed.

Works Cited

Kim, D., & Solomon, M. *Fundamentals of Information System Security*. Jones & Bartlett Learning, 2023.